GreenLeaf Microfinance
ISO 27001:2022 Gap Analysis and Remediation Report

1. Executive Summary

This report presents a simulated ISO/IEC 27001:2022 Annex A gap analysis for GreenLeaf Microfinance, based on the fictional GreenLeaf sandbox application, six external policy templates, the control mapping, and the Task 3 risk register.

The assessment covers 93 Annex A controls. Of these, 82 were classified as Not Implemented and 11 as Partial within the training assessment. These classifications reflect the available documentation and sandbox evidence, not verified deficiencies at a real financial institution.

The risk-based review identified 8 high-priority and 8 medium-priority control gaps, while 77 require further review because no direct risk-register link was established.

2. Assessment Scope and Methodology

This assessment evaluates the fictional GreenLeaf Microfinance training environment against the 93 security controls in ISO/IEC 27001:2022 Annex A.

The assessment scope includes the Node.js/Express sandbox application, its public demonstration endpoints, fictional borrower records, Docker configuration, GitHub source repository, and available security policy reference templates. No real customer information or production financial systems were assessed.

The gap analysis uses Control_Mapping.xlsx from Task 2 as its primary control inventory. Each control's simulated implementation status, evidence notes, and recommended actions were reviewed to identify gaps requiring remediation.

The Task 3 Risk_Register.csv provides ten risk scenarios, scored using likelihood multiplied by impact on a five-point scale. Relevant risk IDs were linked to Annex A controls, and the highest linked risk score was used to establish preliminary remediation priorities.

Controls without a direct risk-register link remain classified as Needs Review. Proposed remediation actions, fictional responsible roles, and estimated completion dates are maintained in Gap_Analysis_Working.xlsx. The initial planning target is 20 November 2026.

This methodology supports a simulated improvement plan and does not constitute an ISO 27001 certification audit or verification of operational effectiveness.

3. Gap Analysis Findings

ISO Control	Control Name	Status	Remediation Action	Responsible Role	Target Date	Linked Risk	Priority
A.5.1	Policies for information security	Partial	Approve an organization-specific policy, assign an owner, communicate it, and establish a review cycle.	GRC Lead	2026-11-20	R-008	High
A.5.2	Information security roles and responsibilities	Not Implemented	Confirm applicability of information security roles and responsibilities, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.3	Segregation of duties	Not Implemented	Confirm applicability of segregation of duties, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.4	Management responsibilities	Not Implemented	Confirm applicability of management responsibilities, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.5	Contact with authorities	Not Implemented	Confirm applicability of contact with authorities, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.6	Contact with special interest groups	Not Implemented	Confirm applicability of contact with special interest groups, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.7	Threat intelligence	Not Implemented	Confirm applicability of threat intelligence, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.8	Information security in project management	Not Implemented	Confirm applicability of information security in project management, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.9	Inventory of information and other associated assets	Not Implemented	Confirm applicability of inventory of information and other associated assets, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.10	Acceptable use of information and other associated assets	Not Implemented	Confirm applicability of acceptable use of information and other associated assets, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review

A.5.11	Return of assets	Not Implemented	Confirm applicability of return of assets, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.12	Classification of information	Partial	Define classification levels and handling rules for real borrower and financial data.	GRC Lead	2026-11-20	R-003	Medium
A.5.13	Labelling of information	Partial	Define labels and verify labels on representative information assets.	GRC Lead	2026-11-20		Needs Review
A.5.14	Information transfer	Not Implemented	Confirm applicability of information transfer, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.15	Access control	Partial	Approve a GreenLeaf-specific access-control policy, define roles and access reviews, and enforce authorization on protected routes.	GRC Lead	2026-11-20	R-001	High
A.5.16	Identity management	Not Implemented	Confirm applicability of identity management, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.17	Authentication information	Not Implemented	Confirm applicability of authentication information, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.18	Access rights	Partial	Confirm applicability of access rights, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.19	Information security in supplier relationships	Not Implemented	Confirm applicability of information security in supplier relationships, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.20	Addressing information security within supplier agreements	Not Implemented	Confirm applicability of addressing information security within supplier agreements, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.21	Managing information security in the ICT supply chain	Not Implemented	Confirm applicability of managing information security in the ict supply chain, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.22	Monitoring, review and change management of supplier services	Not Implemented	Confirm applicability of monitoring, review and change management of supplier services, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.23	Information security for use of cloud services	Not Implemented	Confirm applicability of information security for use of cloud services, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.24	Information security	Partial	Approve an incident management plan with	GRC Lead	2026-11-	R-009	High

	incident management planning and preparation		responsibilities, escalation, and testing.		20		
A.5.25	Assessment and decision on information security events	Partial	Define event assessment criteria and retain triage decision records.	GRC Lead	2026-11-20		Needs Review
A.5.26	Response to information security incidents	Partial	Define response playbooks and conduct a tabletop exercise.	GRC Lead	2026-11-20	R-009	High
A.5.27	Learning from information security incidents	Not Implemented	Confirm applicability of learning from information security incidents, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.28	Collection of evidence	Not Implemented	Confirm applicability of collection of evidence, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.29	Information security during disruption	Partial	Document information security requirements during disruptions and test continuity arrangements.	GRC Lead	2026-11-20		Needs Review
A.5.30	ICT readiness for business continuity	Partial	Define recovery targets and conduct an ICT recovery test.	GRC Lead	2026-11-20		Needs Review
A.5.31	Legal, statutory, regulatory and contractual requirements	Not Implemented	Confirm applicability of legal, statutory, regulatory and contractual requirements, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.32	Intellectual property rights	Not Implemented	Confirm applicability of intellectual property rights, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.33	Protection of records	Not Implemented	Confirm applicability of protection of records, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.34	Privacy and protection of PII	Not Implemented	Confirm applicability of privacy and protection of pii, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.35	Independent review of information security	Not Implemented	Confirm applicability of independent review of information security, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review
A.5.36	Compliance with policies, rules and standards for information security	Not Implemented	Confirm applicability of compliance with policies, rules and standards for information security, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20		Needs Review

A.5.37	Documented operating procedures	Not Implemented	Confirm applicability of documented operating procedures, request owner-approved documentation and operational evidence, then assess effectiveness.	GRC Lead	2026-11-20	Needs Review
A.6.1	Screening	Not Implemented	Confirm applicability of screening, request owner-approved documentation and operational evidence, then assess effectiveness.	HR Manager	2026-11-20	Needs Review
A.6.2	Terms and conditions of employment	Not Implemented	Confirm applicability of terms and conditions of employment, request owner-approved documentation and operational evidence, then assess effectiveness.	HR Manager	2026-11-20	Needs Review
A.6.3	Information security awareness, education and training	Not Implemented	Confirm applicability of information security awareness, education and training, request owner-approved documentation and operational evidence, then assess effectiveness.	HR Manager	2026-11-20	Needs Review
A.6.4	Disciplinary process	Not Implemented	Confirm applicability of disciplinary process, request owner-approved documentation and operational evidence, then assess effectiveness.	HR Manager	2026-11-20	Needs Review
A.6.5	Responsibilities after termination or change of employment	Not Implemented	Confirm applicability of responsibilities after termination or change of employment, request owner-approved documentation and operational evidence, then assess effectiveness.	HR Manager	2026-11-20	Needs Review
A.6.6	Confidentiality or non-disclosure agreements	Not Implemented	Confirm applicability of confidentiality or non-disclosure agreements, request owner-approved documentation and operational evidence, then assess effectiveness.	HR Manager	2026-11-20	Needs Review
A.6.7	Remote working	Not Implemented	Confirm applicability of remote working, request owner-approved documentation and operational evidence, then assess effectiveness.	HR Manager	2026-11-20	Needs Review
A.6.8	Information security event reporting	Not Implemented	Confirm applicability of information security event reporting, request owner-approved documentation and operational evidence, then assess effectiveness.	HR Manager	2026-11-20	Needs Review
A.7.1	Physical security perimeters	Not Implemented	Confirm applicability of physical security perimeters, request owner-approved documentation and operational evidence, then assess effectiveness.	Facilities Manager	2026-11-20	Needs Review
A.7.2	Physical entry	Not Implemented	Confirm applicability of physical entry, request owner-approved documentation and operational evidence, then assess effectiveness.	Facilities Manager	2026-11-20	Needs Review
A.7.3	Securing offices, rooms and facilities	Not Implemented	Confirm applicability of securing offices, rooms and facilities, request owner-approved documentation and operational evidence, then	Facilities Manager	2026-11-20	Needs Review

			assess effectiveness.			
A.7.4	Physical security monitoring	Not Implemented	Confirm applicability of physical security monitoring, request owner-approved documentation and operational evidence, then assess effectiveness.	Facilities Manager	2026-11-20	Needs Review
A.7.5	Protecting against physical and environmental threats	Not Implemented	Confirm applicability of protecting against physical and environmental threats, request owner-approved documentation and operational evidence, then assess effectiveness.	Facilities Manager	2026-11-20	Needs Review
A.7.6	Working in secure areas	Not Implemented	Confirm applicability of working in secure areas, request owner-approved documentation and operational evidence, then assess effectiveness.	Facilities Manager	2026-11-20	Needs Review
A.7.7	Clear desk and clear screen	Not Implemented	Confirm applicability of clear desk and clear screen, request owner-approved documentation and operational evidence, then assess effectiveness.	Facilities Manager	2026-11-20	Needs Review
A.7.8	Equipment siting and protection	Not Implemented	Confirm applicability of equipment siting and protection, request owner-approved documentation and operational evidence, then assess effectiveness.	Facilities Manager	2026-11-20	Needs Review
A.7.9	Security of assets off-premises	Not Implemented	Confirm applicability of security of assets off-premises, request owner-approved documentation and operational evidence, then assess effectiveness.	Facilities Manager	2026-11-20	Needs Review
A.7.10	Storage media	Not Implemented	Confirm applicability of storage media, request owner-approved documentation and operational evidence, then assess effectiveness.	Facilities Manager	2026-11-20	Needs Review
A.7.11	Supporting utilities	Not Implemented	Confirm applicability of supporting utilities, request owner-approved documentation and operational evidence, then assess effectiveness.	Facilities Manager	2026-11-20	Needs Review
A.7.12	Cabling security	Not Implemented	Confirm applicability of cabling security, request owner-approved documentation and operational evidence, then assess effectiveness.	Facilities Manager	2026-11-20	Needs Review
A.7.13	Equipment maintenance	Not Implemented	Confirm applicability of equipment maintenance, request owner-approved documentation and operational evidence, then assess effectiveness.	Facilities Manager	2026-11-20	Needs Review
A.7.14	Secure disposal or re-use of equipment	Not Implemented	Confirm applicability of secure disposal or re-use of equipment, request owner-approved documentation and operational evidence, then assess effectiveness.	Facilities Manager	2026-11-20	Needs Review
A.8.1	User endpoint devices	Not Implemented	Confirm applicability of user endpoint devices, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20	Needs Review

A.8.2	Privileged access rights	Not Implemented	Confirm applicability of privileged access rights, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20		Needs Review
A.8.3	Information access restriction	Not Implemented	Require server-side authentication and role-based authorization before any real borrower records are accessible; verify denial of anonymous requests.	Lead Developer	2026-11-20	R-001	High
A.8.4	Access to source code	Not Implemented	Confirm applicability of access to source code, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20	R-004	High
A.8.5	Secure authentication	Not Implemented	Implement secure server-side authentication and sessions before any real user or sensitive data is introduced.	Lead Developer	2026-11-20	R-002	High
A.8.6	Capacity management	Not Implemented	Confirm applicability of capacity management, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20	R-006	Medium
A.8.7	Protection against malware	Not Implemented	Confirm applicability of protection against malware, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20		Needs Review
A.8.8	Management of technical vulnerabilities	Not Implemented	Confirm applicability of management of technical vulnerabilities, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20		Needs Review
A.8.9	Configuration management	Not Implemented	Confirm applicability of configuration management, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20		Needs Review
A.8.10	Information deletion	Not Implemented	Confirm applicability of information deletion, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20		Needs Review
A.8.11	Data masking	Not Implemented	Confirm applicability of data masking, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20	R-003	Medium
A.8.12	Data leakage prevention	Not Implemented	Confirm applicability of data leakage prevention, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20	R-004	High
A.8.13	Information backup	Not Implemented	Confirm applicability of information backup, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20		Needs Review
A.8.14	Redundancy of information processing facilities	Not Implemented	Confirm applicability of redundancy of information processing facilities, request owner-approved documentation and operational evidence, then	Lead Developer	2026-11-20		Needs Review

			assess effectiveness.				
A.8.15	Logging	Not Implemented	Confirm applicability of logging, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20	R-007	Medium
A.8.16	Monitoring activities	Not Implemented	Confirm applicability of monitoring activities, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20	R-006; R-007	Medium
A.8.17	Clock synchronization	Not Implemented	Confirm applicability of clock synchronization, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20		Needs Review
A.8.18	Use of privileged utility programs	Not Implemented	Confirm applicability of use of privileged utility programs, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20		Needs Review
A.8.19	Installation of software on operational systems	Not Implemented	Confirm applicability of installation of software on operational systems, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20		Needs Review
A.8.20	Networks security	Not Implemented	Confirm applicability of networks security, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20	R-005	Medium
A.8.21	Security of network services	Not Implemented	Confirm applicability of security of network services, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20		Needs Review
A.8.22	Segregation of networks	Not Implemented	Confirm applicability of segregation of networks, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20	R-005	Medium
A.8.23	Web filtering	Not Implemented	Confirm applicability of web filtering, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20		Needs Review
A.8.24	Use of cryptography	Not Implemented	Confirm applicability of use of cryptography, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20		Needs Review
A.8.25	Secure development life cycle	Not Implemented	Confirm applicability of secure development life cycle, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20		Needs Review
A.8.26	Application security requirements	Not Implemented	Confirm applicability of application security requirements, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20		Needs Review
A.8.27	Secure system	Not	Confirm applicability of secure system	Lead	2026-11-		Needs

	architecture and engineering principles	Implemented	architecture and engineering principles, request owner-approved documentation and operational evidence, then assess effectiveness.	Developer	20		Review
A.8.28	Secure coding	Not Implemented	Confirm applicability of secure coding, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20		Needs Review
A.8.29	Security testing in development and acceptance	Not Implemented	Confirm applicability of security testing in development and acceptance, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20		Needs Review
A.8.30	Outsourced development	Not Implemented	Confirm applicability of outsourced development, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20		Needs Review
A.8.31	Separation of development, test and production environments	Not Implemented	Confirm applicability of separation of development, test and production environments, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20		Needs Review
A.8.32	Change management	Partial	Document change approvals, testing, rollback plans, and evidence of completed reviews.	Lead Developer	2026-11-20	R-010	Medium
A.8.33	Test information	Not Implemented	Confirm applicability of test information, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20		Needs Review
A.8.34	Protection of information systems during audit testing	Not Implemented	Confirm applicability of protection of information systems during audit testing, request owner-approved documentation and operational evidence, then assess effectiveness.	Lead Developer	2026-11-20		Needs Review

4. Risk Register Cross-References

The GreenLeaf risk register contains ten distinct risk scenarios linked to relevant ISO/IEC 27001:2022 Annex A controls. These relationships help prioritize remediation activities based on documented risk scores.

Risk ID	ISO Controls	Risk Score	Priority
R-001	A.8.3, A.5.15	12	High
R-002	A.8.5	12	High
R-003	A.5.12,	8	Medium

	A.8.11		
R-004	A.8.4, A.8.12	10	High
	A.8.20,		
R-005	A.8.22	6	Medium
R-006	A.8.6, A.8.16	9	Medium
	A.8.15,		
R-007	A.8.16	9	Medium
R-008	A.5.1	12	High
	A.5.24,		
R-009	A.5.26	12	High
R-010	A.8.32	9	Medium

Risk Score = Likelihood × Impact, using a five-point scale for each factor.

These scores represent preliminary assessments of fictional or simulated scenarios. They do not establish verified security incidents or operational deficiencies at a real financial institution.

5. Remediation Roadmap

The simulated GreenLeaf assessment identifies 93 Annex A control gaps requiring remediation planning.

Preliminary priority distribution:

- High: 8 controls
- Medium: 8 controls
- Low: 0 controls
- Needs Review: 77 controls

Remediation activities should begin with high-priority risks, particularly access restrictions, authentication, information security policies, and incident management.

Each control has a proposed remediation action, responsible role, and target completion date documented in "Gap_Analysis_Working.xlsx". The initial planning target is 20 November 2026.

Controls classified as Needs Review require additional evidence and risk evaluation before their final priority can be determined. These proposed actions and dates are part of a fictional training assessment and do not represent verified organizational commitments.

6. Evidence and Source References

The following project artifacts support the simulated GreenLeaf Microfinance ISO/IEC 27001:2022 gap assessment:

1. Policy_Inventory.pdf: Inventory of six external security policy reference templates, including source URLs.
2. Control_Mapping.xlsx: Mapping of all 93 Annex A controls, implementation statuses, policy references, evidence limitations, and recommended actions.
3. Gap_Analysis_Working.xlsx: Expanded control mapping containing proposed remediation actions, responsible roles, target dates, linked risk IDs, and revised priorities.
4. Risk_Register.csv: Ten risk scenarios with identified assets, threats, vulnerabilities, likelihood, impact, calculated risk scores, and treatment strategies.
5. Methodology.md: Risk assessment methodology defining scoring criteria, risk levels, and assessment limitations.
6. Greenleaf_Assessment_Scope.pdf: Assessment scope, objectives, assets, boundaries, and simulated authorization.

The project README provides additional context and references to supporting assessment files.

All evidence is drawn from the fictional training environment and external reference materials. Policy templates are not evidence of formally approved or operationally implemented GreenLeaf security controls.

7. Assessment Limitations

This assessment was conducted as an educational simulation using the fictional GreenLeaf Microfinance environment. Its findings are limited by the availability of sandbox application evidence and external security policy reference templates.

The assessment did not involve production infrastructure, real customer information, organizational interviews, formal management approvals, or comprehensive technical security testing.

The 82 Not Implemented and 11 Partial control classifications represent simulated assessment gaps. They do not establish actual security deficiencies at a real financial institution.

Risk likelihood and impact scores are preliminary estimates. Controls without directly linked risk scenarios remain classified as Needs Review and require further evaluation before final prioritization.

Remediation actions, responsible roles, and target completion dates are proposed for training purposes only. Their feasibility, effectiveness, and organizational approval have not been independently verified.

This report does not constitute ISO/IEC 27001 certification, an accredited audit, or assurance of regulatory compliance.